SI6007 · DESARROLLO DE SISTEMAS SEGUROS · UNIVERSIDAD EAFIT

Verificación de seguridad nivel 1 del marketplace

Aplicación de OWASP ASVS 5.0.0 sobre el modelo de amenazas de la Entrega 2 (Silk Road y Coupang) y su archivo `Marketplace_SergioJunca.tm7`

Sergio Alfredo Junca Valero · Profesor Manuel Humberto Santander Peláez · Octubre de 2026

> Este documento verifica, a nivel 1 (L1), el marketplace que ya modelé en la Entrega 2: un comprador y un vendedor alrededor de una plataforma con login, catálogo y pedidos, pagos y retiros, servidores y secretos, y logs — los mismos cinco puntos de falla que allí comparé entre el caso Silk Road (2012-2014) y el caso Coupang (2024-2026). Esta vez no repito la investigación de esos dos casos: la uso como evidencia para decidir, requisito por requisito, si el diseño los resuelve.

1. Introducción

El taller pide verificar en nivel 1 el proyecto que cada quien ya modeló con el Microsoft Threat Modeling Tool. Sigo los mismos cuatro pasos que un ejemplo de verificación visto en clase: delimitar el alcance, revisar el modelo de amenazas, evaluar cada requisito L1 y reportar el resultado con su plan de trabajo.

La verificación usa un solo estándar: **OWASP ASVS 5.0.0**. No uso AISVS (el complemento de IA de OWASP) porque el marketplace de la Entrega 2 no tiene ningún componente de inteligencia artificial — ni asistente, ni modelo de fraude, ni recomendador. Forzar esa evaluación habría significado inventar una pieza que mi proyecto no tiene, y la instrucción del curso es explícita: no inventar datos ni resultados.

El documento es corto a propósito: en vez de diseñar un marketplace nuevo y más grande, verifico el que ya existe y dejo cada vacío real a la vista en vez de disimularlo con alcance adicional.

2. Alcance de la verificación

2.1 Sistema evaluado

El marketplace conecta un comprador y un vendedor a través de cinco piezas: **login y autenticación** (quién eres), **catálogo y pedidos** (qué se vende y se compra), **pagos y retiros** (el dinero, incluida la liquidación al vendedor), **servidores y secretos** (llaves, configuración, paneles de administración) y **logs y monitoreo** (detectar, probar y responder). El pago en sí lo procesa una **pasarela externa regulada**; el marketplace nunca ve el número de tarjeta. Personal interno (soporte y desarrollo) accede a servidores y configuración.

Esta es la misma arquitectura de la Figura 1 de la Entrega 2, redibujada aquí como diagrama de flujo de datos con la notación del curso. Los cinco números son los mismos cinco puntos de falla de esa entrega — ahora cada uno se verifica contra un requisito real de ASVS en la sección 3.2.

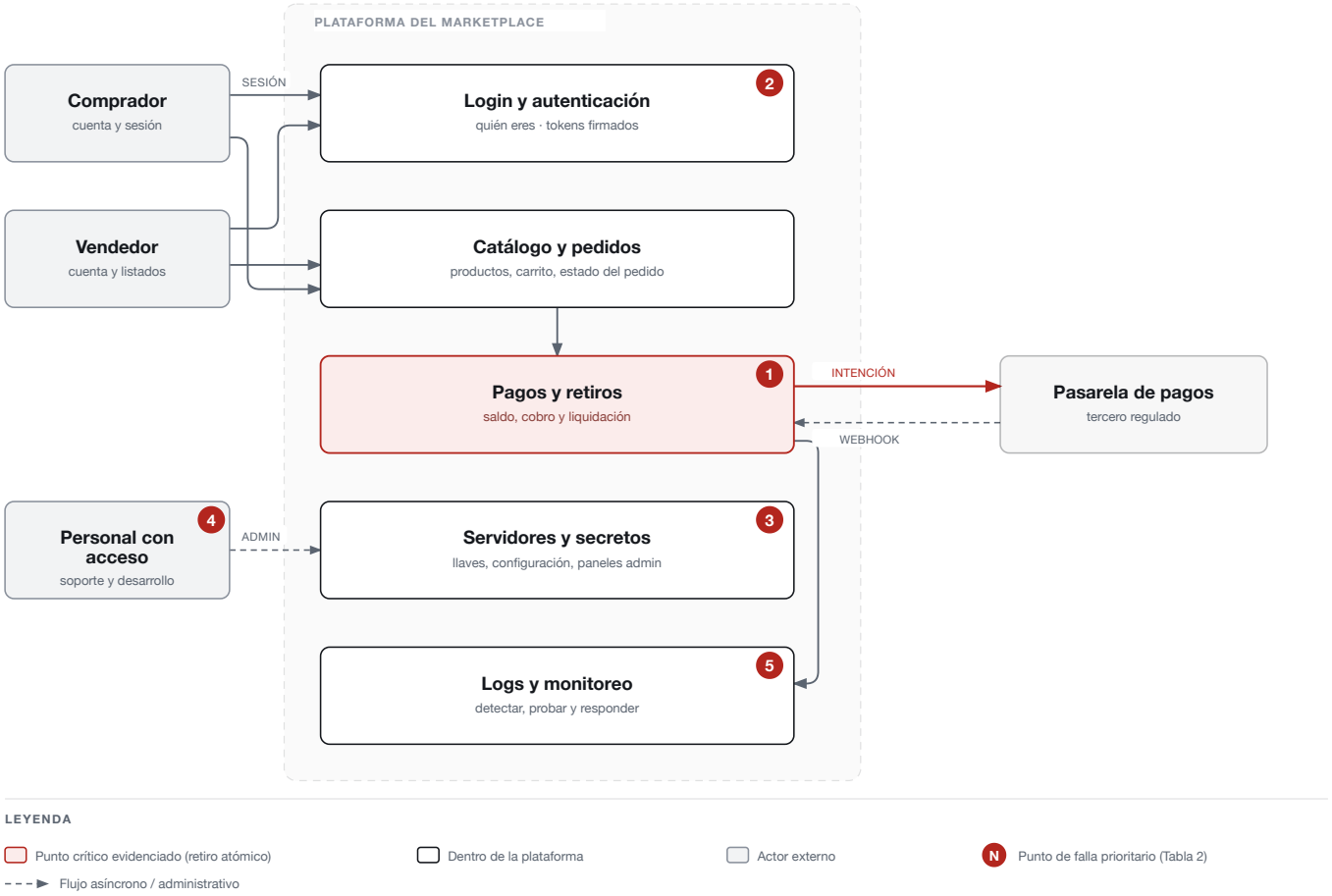


Figura 1. Arquitectura del marketplace por zona de confianza, con los 5 puntos de falla de la Entrega 2 numerados. Elaboración propia. Notación DFD: rectángulo para actor externo o proceso, línea punteada para frontera de confianza.

2.2 Estándar, versión y forma de citar

Se usó **ASVS 5.0.0** (OWASP Foundation, 2025), publicado en mayo de 2025: 345 requisitos en total, de los cuales **70 son de nivel 1** — cifra confirmada contra el CSV oficial del repositorio del estándar, no copiada de memoria. Cada requisito se cita con su versión, como recomienda el proyecto: `v5.0.0-6.2.4` en vez de solo `6.2.4`, porque los identificadores pueden cambiar entre versiones.

2.3 Nivel objetivo

El taller pide L1. Es el punto de partida correcto para un proyecto de curso, pero un marketplace real que mueve dinero de terceros y datos personales (Ley 1581 de 2012) es, por definición de los propios niveles de ASVS, un sistema L2. La sección 6.4 cierra con la ruta hacia ese nivel.

2.4 Tipo de verificación y supuestos

Es una verificación **de diseño**: el marketplace no está desplegado, así que la evidencia son decisiones de arquitectura, no código en ejecución. Lo que solo se puede comprobar desplegado queda *Pendiente*, con la verificación que lo cerraría. Supuestos declarados para poder evaluar:

- La autenticación es propia (usuario/contraseña + política declarada en 4.1 de V6), con sesión representada por **tokens autocontenidos firmados**. No se delega el login a un proveedor externo vía OAuth/OIDC.
- Los datos de tarjeta no pasan por el marketplace: viajan del navegador a la pasarela; el servicio de Pagos solo guarda referencias y el saldo/estado de la cuenta del vendedor.
- No hay carga de archivos (imágenes de producto) diseñada en este ejercicio — ver Exclusiones.
- No hay procesamiento de XML (sin facturación electrónica ni integraciones que lo requieran) ni conexiones WebSocket.

2.5 Exclusiones

- **AISVS completo:** no aplica — el sistema no tiene componentes de IA (OWASP Foundation, 2026).
- **V10 OAuth and OIDC** (5 requisitos L1): N.A. por el supuesto de autenticación propia (2.4).
- **V4.4.1** (WebSocket sobre TLS) y **V1.5.1** (XXE/parsers XML): N.A., el diseño no usa ninguno de los dos.
- **V5 File Handling** (4 requisitos L1): la carga de imágenes de producto no se diseñó en este ejercicio; quedan *Pendiente*, no N.A., porque un marketplace real sí la va a necesitar.

3. Modelo de amenazas

3.1 Diagnóstico del modelo real (.tm7)

`Marketplace_SergioJunca.tm7` (plantilla SDL TM Knowledge Base Core, validado con el código del Threat Modeling Tool 7.3 el 17-oct-2026) genera **74 amenazas STRIDE** sobre la frontera de confianza "Plataforma del marketplace" y sus 13 flujos. Las 74 están en estado *Not Started*: la herramienta las generó, pero nadie las ha triado todavía — mismo punto de partida que cualquier modelo recién generado, antes de revisar amenaza por amenaza.

Esta verificación no re-triaje las 74 una por una: sería repetir trabajo de modelado, no de verificación ASVS. En su lugar, toma las **5 amenazas ya priorizadas** en la Entrega 2 — que surgen de dos incidentes reales, no de la salida genérica de la herramienta — y las conecta con requisitos concretos. Triar las 69 amenazas restantes del `.tm7` queda en el plan de remediación (6.3).

3.2 Amenazas prioritarias

La Tabla 1 retoma los cinco puntos de falla de la Entrega 2 (Silk Road 2012-2014 frente a Coupang 2024-2026) y los conecta con los requisitos L1 de ASVS que los cierran o los dejan abiertos.

Tabla 1. Amenazas prioritarias y su requisito ASVS 5.0.0

N.º	Amenaza (origen)	STRIDE	Requisito L1 decisivo	Estado
1	Validación crítica en el retiro: más de 50.000 BTC movidos con retiros en rápida sucesión.	T	v5.0.0-2.2.1 / 2.2.2 — validación de negocio forzada en el servidor	**Cumple** — retiro atómico (5.1)
2	Cuentas falsas (registro abierto) y tokens de login falsificados con una llave filtrada.	S, I	v5.0.0-6.1.1 (rate limiting) + v5.0.0-9.1.3 (origen de la llave)	**Cumple** / *Pendiente*
3	Secretos y configuración: servidor alcanzable fuera de Tor; llave de firma sin rotar al salir un ingeniero.	I	v5.0.0-7.4.1 — invalidar sesiones/rotar la llave de firma	**Cumple** — diseño (5.2)
4	Personas con acceso: rastros propios del operador; un exempleado conocía las fallas de autenticación.	E	v5.0.0-7.4.2 — terminar sesiones al dar de baja una cuenta	**Cumple** — diseño (5.2)
5	Detectar y responder: fuga de IP hallada por un DDoS; meses sin detectar y logs borrados.	R	V16 Security Logging — **sin requisitos L1** en ASVS 5.0.0	Ver 6.2 y 6.4

STRIDE: S suplantación, T manipulación, R repudio, I divulgación, E elevación de privilegios.

3.3 Reglas de autorización

La Tabla 2 es la documentación de autorización que pide `v5.0.0–8.1.1`: qué puede hacer cada rol sobre cada recurso. Es la evidencia de que V8 (Authorization) sí quedó diseñado, aunque el sistema no esté desplegado.

Tabla 2. Matriz de autorización por rol

Acción	Comprador	Vendedor	Personal con acceso
Ver catálogo	Sí	Sí	Sí
Crear pedido / pagar	Propio	No	No
Ver pedido	Propio	De su tienda, filtrado por su cuenta	Con registro (soporte)
Publicar producto	No	Propio	No
Retirar saldo / liquidación	No	Propia, con reautenticación	Aprobar montos altos (finanzas)
Cambiar cuenta de liquidación	No	Propia, reautenticando	No
Administrar servidores/secretos	No	No	Sí, con acceso de mínimo privilegio

4. Evaluación

4.1 Criterios de estado

Estado	Significado
Cumple	El diseño resuelve el requisito con una decisión de arquitectura o de documentación verificable sin desplegar el sistema.
Heredado	Lo resuelve un servicio administrado externo. **No se usa en esta versión** — a diferencia del ejemplo visto en clase, este diseño no delega en un proveedor de identidad ni de borde, así que no hay ningún requisito en este estado.
Pendiente	El requisito describe un comportamiento de la aplicación en ejecución (código, configuración fina, datos ya cargados) que no se puede confirmar desde un diseño no desplegado.
N.A.	El componente o escenario no existe en el alcance declarado (2.5), con su justificación.

4.2 Resultados de ASVS 5.0.0

De los **70 requisitos L1**, **26 pasan por diseño** (37 %), **37 quedan Pendiente** de verificar en código o configuración (53 %) y **7 no aplican** (10 %) a este sistema. El detalle completo, requisito por requisito, está en el Anexo A.

El patrón no es casualidad: los capítulos que son decisiones de *arquitectura* — V7 Session Management, V8 Authorization, V9 Self-contained Tokens, V11 Cryptography, V12 Secure Communication — pasan casi en su totalidad, porque son exactamente las decisiones que ya tomé al diseñar el flujo de tokens y la matriz de roles. Los capítulos que piden *comportamiento verificado en código* — V3 Web Frontend Security, buena parte de V6 Authentication (composición de contraseña, campos del formulario) — quedan Pendiente casi en su totalidad, porque ninguna decisión de diseño por sí sola prueba que el formulario real enmascara el campo o que el backend compara la contraseña sin truncarla.

4.3 Hallazgos principales

- **El hallazgo central (v5.0.0-9.1.3):** el diseño valida la firma del token (`v5.0.0–9.1.1`, Cumple) pero no especifica de dónde sale ni cómo se distribuye la llave de verificación. Es exactamente la causa raíz del caso Coupang — una llave de firma que siguió siendo válida después de que su dueño se fue — y es el único punto donde el diseño actual, tal como está escrito, repetiría ese incidente.
- **V16 (Security Logging) no tiene requisitos L1** en ASVS 5.0.0 — ninguno. Las amenazas de repudio y de falta de detección que genera el `.tm7` (punto 5, Tabla 1) no se cierran con una verificación L1, sin importar qué tan bien esté diseñado el sistema.
- **V5 (carga de archivos) queda Pendiente en bloque:** un marketplace real necesita que el vendedor suba imágenes de producto, y esa pieza nunca se diseñó. No es una omisión de esta verificación: es un vacío real del proyecto que esta verificación deja visible en vez de ocultar.

5. Evidencia

5.1 Retiro atómico (v5.0.0-2.2.1 / 2.2.2)

La evidencia de la amenaza 1 (Tabla 1) es la misma regla propuesta en la Entrega 2: el retiro se valida y se aplica en una sola operación atómica en la base de datos, no en dos pasos separados que una segunda petición concurrente pueda intercalar.

```
UPDATE cuentas SET saldo = saldo - :monto
WHERE id = :id AND saldo >= :monto;
-- 0 filas afectadas: rechazar el retiro
-- Red de seguridad adicional: CHECK (saldo >= 0)
```

La Figura 2 muestra por qué separar "leer el saldo" de "descontarlo" — el patrón que perdió a Silk Road más de 50.000 BTC (Amick, 2022) — no resiste dos peticiones concurrentes, y por qué el UPDATE atómico sí.

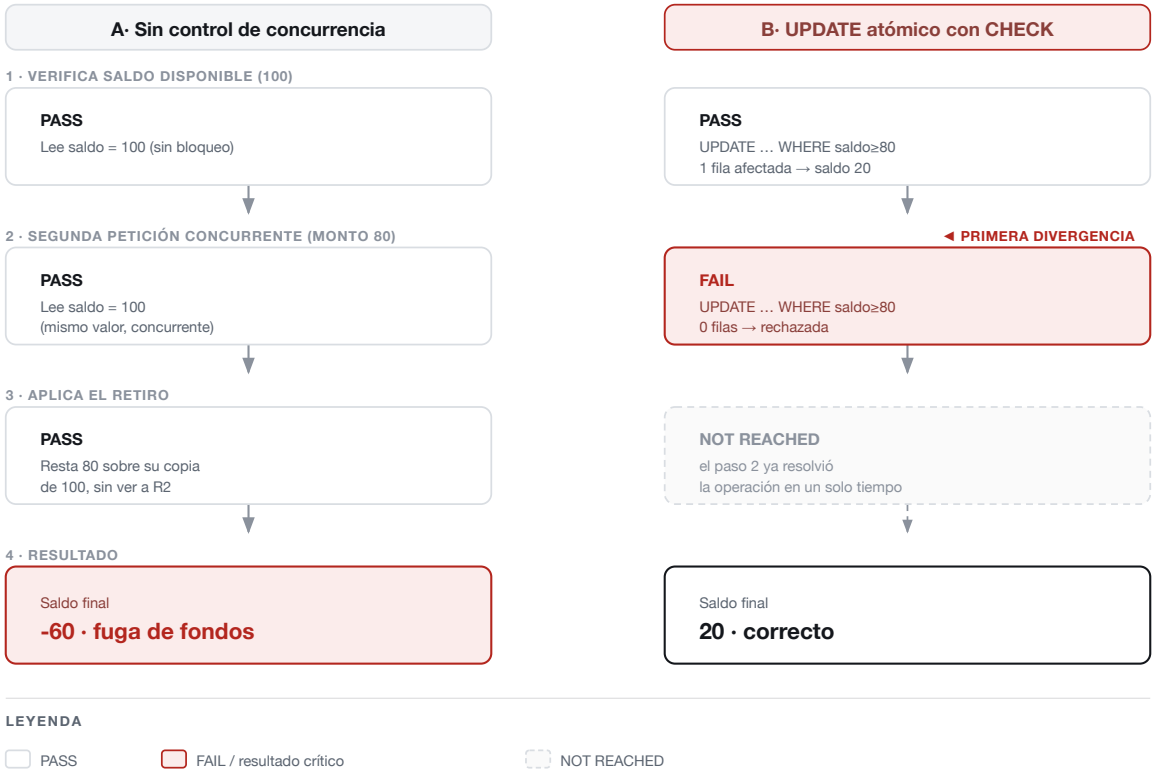


Figura 2. Dos retiros concurrentes de 80 sobre un saldo de 100: sin control de concurrencia ambos pasan y el saldo queda en -60; con el UPDATE atómico, el segundo se rechaza con 0 filas afectadas y el saldo queda en 20. Elaboración propia.

5.2 Otros controles ya documentados

- **v5.0.0-6.1.1 / 6.1.1 (cuentas falsas, amenaza 2):** límite de tasa por cuenta e IP, WAF y fail2ban contra registro masivo y fuerza bruta — documentado en la Entrega 2, visto en clase.
- **v5.0.0-7.4.1 y 7.4.2 (secretos y personas, amenazas 3 y 4):** rotación de la llave de firma y terminación de todas las sesiones activas el día de la baja de una cuenta — la misma decisión de la Entrega 2 ("revocación el día de la baja"), ahora mapeada a su requisito exacto.
- **v5.0.0-8.1.1 / 8.2.1 / 8.2.2 (amenaza 1, BOLA):** la matriz de roles (Tabla 2) y la regla de que Pedidos filtra siempre por el comprador o vendedor autenticado.
- **v5.0.0-11.3.1 / 11.3.2 / 11.4.1 y v5.0.0-12.1.1 / 12.2.1 / 12.2.2:** decisiones de línea base — TLS 1.2/1.3 en todo el borde, AES-GCM, sin MD5 ni modos inseguros.

6. Reporte

6.1 Resumen

70 requisitos L1 evaluados: **26 Cumple**, **0 Heredado**, **37 Pendiente**, **7 N.A.** Para efectos del taller, un requisito pasa en Cumple o Heredado y falla en Brecha; Pendiente no se cuenta como aprobado ni como reprobado — el control está definido, falta demostrarlo en código. No hay ningún requisito en Brecha: donde el diseño no resolvía algo, la opción fue definirlo ahora (y queda Cumple con esa decisión) o dejarlo Pendiente de forma explícita, nunca darlo por bueno sin evidencia.

6.2 Excepciones

- **AISVS:** no se evaluó. El marketplace no tiene componentes de IA; forzar la evaluación habría significado inventar un asistente o un modelo de fraude que el proyecto no tiene.
- **V16 Security Logging:** 0 requisitos L1 en ASVS 5.0.0. La amenaza 5 (detectar y responder) queda sin cierre posible en este nivel — ver 6.4.
- **Gestión de secretos (vault, rotación programada):** es nivel 2 en ASVS 5.0.0 (v5.0.0–13.3.1, 13.3.2), no nivel 1. V13 solo tiene un requisito L1 (metadatos de control de versiones), que sí se cumple.

6.3 Plan de remediación

Prioridad	Acción	Cuándo
1 · v5.0.0-9.1.3	Especificar el origen y la distribución controlada de la llave de verificación de tokens (vault, rotación operativa, no solo el algoritmo).	Antes de implementar login — cierra el hallazgo central (4.3)
2 · V5 completo	Diseñar la carga de imágenes de producto (tamaño, tipo real de archivo, carpeta no ejecutable) y evaluar sus 4 requisitos L1.	Antes de construir el catálogo
3 · tm7	Triar las 69 amenazas *Not Started* restantes del modelo (estado, prioridad, justificación), no solo las 5 priorizadas aquí.	Siguiente iteración del modelo
4 · V3 / V6.2	Fijar la configuración fina pendiente: cabeceras (HSTS, CORS, CSP), cookies y los detalles de comportamiento del formulario de contraseña.	Al construir el frontend

6.4 Ruta hacia L2

Un marketplace que mueve dinero de terceros y datos personales protegidos por la Ley 1581 de 2012 es, por la propia definición de niveles de ASVS, un sistema L2. Tres de los refuerzos L2/L3 ya identificados en este ejercicio apuntan exactamente a los puntos más débiles de la Tabla 1: v5.0.0–2.3.4 (bloqueos de negocio contra doble reserva, refuerzo del retiro atómico), v5.0.0–11.1.1 (ciclo de vida documentado de llaves criptográficas, cierre definitivo de la amenaza 2/3) y v5.0.0–13.3.1/13.3.2 (gestor de secretos con mínimo privilegio). Ninguno de los tres existe en L1 — por eso una verificación L1, aunque pase, no es suficiente para un sistema con este perfil de riesgo.

7. Conclusiones

El marketplace de la Entrega 2 pasa 26 de 70 requisitos L1 por diseño, sin ningún requisito en Brecha abierta: donde faltaba una decisión barata de tomar (política de contraseñas, algoritmo de cifrado, plazos de remediación), se tomó aquí mismo; donde faltaba algo que solo el código puede probar, quedó Pendiente y declarado. El hallazgo que más importa no es un número: es que el único requisito de verdad sin resolver en el núcleo de autenticación — de dónde sale la llave que valida los tokens — es exactamente la causa que tumbó a Coupang. Verificar contra un estándar sirve para eso: convertir una lección aprendida de otro incidente en un requisito con nombre propio en el propio diseño, en vez de una anécdota.

El ejercicio también confirma algo que ya sabía por la Entrega 1: un proyecto pequeño y honesto sobre lo que no ha resuelto vale más, para una verificación de seguridad, que uno grande que da por buenos requisitos que el sistema real no cumple.

Referencias

Aegerter, G. (2013, 2 de octubre). *End of Silk Road: Slip-ups in building Internet drug market led to Ross Ulbricht, court documents say*. NBC News. https://www.nbcnews.com/news/world/end-silk-road-slip-ups-building-internet-drug-market-led-flna8C11326181

Amick, S. (2022, 7 de noviembre). *U.S. Department of Justice seized over $3.36 billion in bitcoin tied to Silk Road*. Bitcoin Magazine. https://bitcoinmagazine.com/markets/us-department-of-justice-seizes-over-3-billion-bitcoin

Biggs, J. (2014, 13 de febrero). *Silk Road 2 hacked, over 4,000 bitcoin allegedly stolen*. TechCrunch. https://techcrunch.com/2014/02/13/silk-road-2-hacked-88000-bitcoin-allegedly-stolen

Congreso de la República de Colombia. (2012). *Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales*. Diario Oficial No. 48.587.

Gatlan, S. (2026, 11 de junio). *Coupang hit with record $409 million data breach fine in Korea*. BleepingComputer. https://www.bleepingcomputer.com/news/security/south-korea-hits-coupang-with-record-409-million-fine-over-data-breach/

Lee, J.-S. (2026, 11 de junio). *Coupang hit with record 624.6 billion won fine over data breach of 37.5 million*. Seoul Economic Daily. https://en.sedaily.com/technology/2026/06/11/coupang-hit-with-record-6246-billion-won-fine-over-data

OWASP Foundation. (2025). *OWASP Application Security Verification Standard 5.0.0*. https://github.com/OWASP/ASVS

OWASP Foundation. (2025). *OWASP Top 10:2025*. https://top10.owasp.org/2025/0x00_2025-Introduction

OWASP Foundation. (2026). *OWASP Artificial Intelligence Security Verification Standard (AISVS) 1.01*. https://github.com/OWASP/AISVS

Schneier, B. (2014, 20 de octubre). *How did the feds identity [sic] Dread Pirate Roberts?* Schneier on Security. https://www.schneier.com/blog/archives/2014/10/how_did_the_fed.html

Tarbell, C. (2014, 5 de septiembre). *Declaration of Christopher Tarbell* (S1 14 Cr. 68 (KBF)) [Declaración jurada]. U.S. District Court, Southern District of New York. https://www.emptywheel.net/wp-content/uploads/2014/10/140905-Tarbell-Declaration.pdf

Yang, H., y Jin, H. (2026, 10 de febrero). *South Korea blames Coupang data breach on management failure, not sophisticated attack*. Reuters. https://finance.yahoo.com/news/south-korea-says-coupang-must-051616142.html

Anexo A. Matriz completa de verificación — ASVS 5.0.0, nivel 1 (70 requisitos)

Descripciones resumidas en español; el texto oficial de cada requisito está en el repositorio del estándar (OWASP Foundation, 2025). 26 Cumple · 0 Heredado · 37 Pendiente · 7 N.A.

Requisito	Descripción (resumen)	Estado	Justificación
V1 · Encoding and Sanitization			
v5.0.0-1.2.1	Codificar la salida segun el contexto (HTML, atributo, CSS, cabecera) en cada respuesta.	*Pendiente*	Codificacion de salida por contexto: se verifica en el framework/codigo, no en el diseño.
v5.0.0-1.2.2	Codificar los datos no confiables al construir URLs; solo protocolos seguros (no javascript:/data:).	*Pendiente*	Codificacion de URLs dinamicas: se verifica en codigo.
v5.0.0-1.2.3	Codificar o escapar al construir JavaScript/JSON dinamico.	*Pendiente*	Codificacion de contenido JS/JSON dinamico: se verifica en codigo.
v5.0.0-1.2.4	Consultas parametrizadas u ORM para SQL/NoSQL; nunca concatenar entrada del usuario.	*Pendiente*	Consultas parametrizadas (anti-SQLi): se verifica en el ORM/consultas reales.
v5.0.0-1.2.5	Proteger contra inyeccion de comandos del sistema operativo.	*Pendiente*	Anti-inyeccion de comandos de SO: no hay llamadas a SO documentadas; se verifica en codigo si llegan a existir.
v5.0.0-1.3.1	Sanitizar con una libreria conocida el HTML que llega de editores enriquecidos.	*Pendiente*	Sanitizacion de HTML de terceros (p. ej. descripciones de producto): se verifica en codigo/libreria.
v5.0.0-1.3.2	Evitar eval() u otra ejecucion dinamica de codigo con entrada de usuario.	*Pendiente*	Uso de eval()/codigo dinamico: se verifica en codigo.
v5.0.0-1.5.1	Parsers XML con configuracion restrictiva (sin entidades externas, anti-XXE).	*N.A.*	El diseño no incluye facturacion electronica ni otro insumo XML (ver 2.5); no hay parser XML en el alcance.
V2 · Validation and Business Logic			
v5.0.0-2.1.1	Documentar las reglas de validacion esperadas para cada tipo de dato.	*Pendiente*	Falta un documento general de reglas de validacion por campo; solo esta especificada la regla del retiro (ver 2.2.1).
v5.0.0-2.2.1	Validar la entrada contra reglas de negocio (lista positiva o limites logicos).	**Cumple**	Retiro atomico: UPDATE saldo=saldo-:monto WHERE saldo>=:monto valida la decision de negocio critica antes de aplicarla (evidencia 5.1).
v5.0.0-2.2.2	Forzar la validacion en una capa de servicio confiable, no solo en el cliente.	**Cumple**	La misma regla se aplica en la base de datos (capa de servicio confiable), no en el navegador.
v5.0.0-2.3.1	Procesar los flujos de negocio solo en el orden secuencial esperado, sin saltar pasos.	*Pendiente*	Orden secuencial del flujo de checkout: no se diseño en este ejercicio.
V3 · Web Frontend Security			
v5.0.0-3.2.1	Evitar que el navegador renderice una respuesta fuera de su contexto previsto.	*Pendiente*	Cabeceras Sec-Fetch-* / Content-Disposition: configuracion fina del borde, no decidida aun.
v5.0.0-3.2.2	Mostrar contenido como texto (no HTML) con funciones seguras de render.	*Pendiente*	Render seguro de texto no confiable (reseñas, nombres de producto): se verifica en el frontend real.
v5.0.0-3.3.1	Cookies con atributo Secure y prefijo __Host-/__Secure-.	*Pendiente*	Atributo Secure/prefijo __Host- en cookies: configuracion de sesion pendiente de fijar.
v5.0.0-3.4.1	Cabecera Strict-Transport-Security (HSTS) en todas las respuestas.	*Pendiente*	Cabecera HSTS: depende del borde/CDN elegido, no decidido en este ejercicio.
v5.0.0-3.4.2	Access-Control-Allow-Origin fijo o validado contra una lista blanca de origenes.	*Pendiente*	Lista blanca de origenes CORS: no definida.
v5.0.0-3.5.1	Mitigar CSRF en funciones sensibles cuando no se depende del preflight CORS.	*Pendiente*	Token/cabecera anti-CSRF: no definido.
v5.0.0-3.5.2	Si se depende del preflight CORS, impedir llamadas que no lo disparen.	*Pendiente*	Validacion de preflight CORS: no definida.
v5.0.0-3.5.3	Usar metodos HTTP no “seguros” (POST/PUT/PATCH/DELETE) para funciones sensibles.	*Pendiente*	Metodos HTTP por sensibilidad (POST/PUT/DELETE vs GET): no auditado.
V4 · API and Web Service			
v5.0.0-4.1.1	Cabecera Content-Type correcta (con charset) en cada respuesta con cuerpo.	*Pendiente*	Cabecera Content-Type correcta en cada respuesta: se verifica en la API real.
v5.0.0-4.4.1	Usar WebSocket solo sobre TLS (WSS).	*N.A.*	El diseño no usa WebSocket (catalogo, pedidos y pagos son solo HTTP/HTTPS).
V5 · File Handling			
v5.0.0-5.2.1	Limitar el tamano de archivo aceptado para evitar denegacion de servicio.	*Pendiente*	Limite de tamaño de archivo: la carga de imagenes de producto no se diseño en este ejercicio (ver 2.5).

Requisito	Descripción (resumen)	Estado	Justificación
v5.0.0-5.2.2	Validar que el contenido real del archivo coincide con su extension declarada.	*Pendiente*	Validacion de tipo real de archivo (magic bytes): idem, fuera de este ejercicio.
v5.0.0-5.3.1	Los archivos subidos a una carpeta publica no se ejecutan como codigo del servidor.	*Pendiente*	Archivos subidos no ejecutables como codigo: idem.
v5.0.0-5.3.2	Construir rutas de archivo con datos internos, no con nombres del usuario (anti path traversal/SSRF).	*Pendiente*	Rutas de archivo sin datos de usuario (anti path traversal/SSRF): idem.
V6 · Authentication			
v5.0.0-6.1.1	Documentar como se usan rate limiting y anti-automatizacion contra fuerza bruta.	**Cumple**	Documentado en Entrega 2 (punto 2): limite de tasa por cuenta e IP, WAF y fail2ban contra fuerza bruta y registro masivo.
v5.0.0-6.2.1	Contrasenas de al menos 8 caracteres (se recomienda 15).	*Pendiente*	Longitud minima de contraseña: valor de configuracion aun no fijado en el proveedor de credenciales.
v5.0.0-6.2.2	El usuario puede cambiar su contrasena.	*Pendiente*	Funcion de cambio de contraseña: se verifica en la aplicacion real.
v5.0.0-6.2.3	Cambiar la contrasena exige la actual y la nueva.	*Pendiente*	Exigir contraseña actual y nueva al cambiarla: se verifica en codigo.
v5.0.0-6.2.4	Rechazar contrasenas presentes en una lista de al menos 3000 filtradas.	*Pendiente*	Verificacion contra lista de contraseñas filtradas: integracion no definida.
v5.0.0-6.2.5	No imponer reglas de composicion (mayusculas, numeros, simbolos obligatorios).	*Pendiente*	Ausencia de reglas de composicion restrictivas: se verifica en el formulario real.
v5.0.0-6.2.6	Campo de contrasena enmascarado (type=password).	*Pendiente*	Campo tipo password en el formulario: se verifica en el frontend real.
v5.0.0-6.2.7	Permitir pegar la contrasena y el uso de gestores de contrasenas.	*Pendiente*	Permitir pegar y gestores de contraseña (sin JS que lo bloquee): se verifica en el frontend real.
v5.0.0-6.2.8	Verificar la contrasena exactamente como se recibe, sin truncar ni transformar.	*Pendiente*	Comparacion exacta de contraseña sin truncar/transformar: se verifica en el backend real.
v5.0.0-6.3.1	Implementar en el sistema real los controles anti fuerza bruta ya documentados.	*Pendiente*	Que lo implementado coincida con lo documentado en 6.1.1: requiere el sistema desplegado.
v5.0.0-6.3.2	Sin cuentas por defecto (root/admin/sa) presentes o sin deshabilitar.	*Pendiente*	Ausencia de cuentas por defecto (root/admin/sa): se verifica en el entorno desplegado.
v5.0.0-6.4.1	Contrasenas o codigos iniciales generados por el sistema, aleatorios y de corta vigencia.	*Pendiente*	Expiracion de contraseñas/codigos iniciales: comportamiento a verificar en codigo.
v5.0.0-6.4.2	Sin preguntas secretas ni pistas de contrasena.	**Cumple**	Decision de diseño: no se usan preguntas secretas; el restablecimiento es por enlace de un solo uso al correo verificado.
V7 · Session Management			
v5.0.0-7.2.1	La verificacion de la sesion ocurre en un servicio backend confiable.	**Cumple**	Decision de arquitectura: la verificacion de sesion ocurre en un servicio backend, nunca solo en el cliente.
v5.0.0-7.2.2	Tokens de sesion dinamicos, no claves API estaticas.	**Cumple**	Decision de arquitectura: tokens autocontenidos generados dinamicamente por sesion, sin claves API estaticas.
v5.0.0-7.2.3	Tokens de referencia generados con CSPRNG y al menos 128 bits de entropia.	*Pendiente*	Entropia/CSPRNG de tokens de referencia: no se usan tokens de referencia en este diseño (solo autocontenidos); verificar si se introducen.
v5.0.0-7.2.4	Emitir un token nuevo en cada autenticacion o reautenticacion.	**Cumple**	Decision de arquitectura: se emite un token nuevo en cada autenticacion o reautenticacion, invalidando el anterior.
v5.0.0-7.4.1	Invalidar de verdad la sesion al cerrarla (lista de revocados o rotacion de llave).	**Cumple**	Resuelve el hallazgo de Coupang (punto 2): rotacion de la llave de firma por usuario/servicio al revocar, documentado en Entrega 2 ('revocacion el dia de la baja').
v5.0.0-7.4.2	Terminar todas las sesiones activas al deshabilitar o eliminar una cuenta.	**Cumple**	Resuelve el hallazgo de personas con acceso (punto 4): terminar todas las sesiones activas al deshabilitar una cuenta, documentado en Entrega 2 ('baja verificada').
V8 · Authorization			
v5.0.0-8.1.1	Documentar las reglas de autorizacion por funcion y por dato.	**Cumple**	Esta verificacion documenta las reglas de autorizacion por rol y recurso (Tabla 3, seccion 3.3).
v5.0.0-8.2.1	Restringir el acceso a nivel de funcion a permisos explicitos.	**Cumple**	La matriz de roles restringe cada accion a permisos explicitos por rol (Tabla 3).
v5.0.0-8.2.2	Restringir el acceso a nivel de dato (anti-IDOR/BOLA).	**Cumple**	Decision de arquitectura: Pedidos y Catalogo filtran por el vendedor o comprador autenticado; anti-BOLA/IDOR por diseño.

Requisito	Descripción (resumen)	Estado	Justificación
v5.0.0–8.3.1	Aplicar la autorizacion en el servidor, nunca solo en JavaScript del cliente.	**Cumple**	Decision de arquitectura: las reglas de autorizacion se aplican en el backend, nunca en JavaScript del cliente.
V9 · Self-contained Tokens			
v5.0.0–9.1.1	Validar la firma/MAC del token autocontenido antes de confiar en su contenido.	**Cumple**	Los tokens se validan por firma/MAC antes de aceptar su contenido (ya era cierto en el caso Coupang; el fallo estaba en el ciclo de vida de la llave, no aqui).
v5.0.0–9.1.2	Restringir los algoritmos de firma a una lista blanca; nunca aceptar 'none'.	**Cumple**	Decision de diseño: un unico algoritmo de firma permitido en la lista blanca; se rechaza 'none'.
v5.0.0–9.1.3	La llave de verificacion viene solo de fuentes preconfiguradas y confiables.	*Pendiente*	Brecha real identificada: falta especificar el origen/distribucion controlada de la llave de verificacion y su rotacion operativa (causa raiz del caso Coupang).
v5.0.0–9.2.1	Validar la vigencia del token (exp/nbf) en cada verificacion.	**Cumple**	Decision de diseño: se valida la vigencia del token (exp/nbf) en cada verificacion.
V10 · OAuth and OIDC			
v5.0.0–10.4.1	Validar la redirect URI contra una lista blanca exacta por cliente.	*N.A.*	El diseño no delega el login a un proveedor externo via OAuth/OIDC (autenticacion propia, ver 2.4).
v5.0.0–10.4.2	El codigo de autorizacion se usa una sola vez; revocar tokens si se reutiliza.	*N.A.*	Idem: no hay flujo de autorizacion OAuth en este diseño.
v5.0.0–10.4.3	Codigo de autorizacion de vida corta (hasta 10 min en L1/L2).	*N.A.*	Idem.
v5.0.0–10.4.4	Cada cliente solo puede usar los grants que necesita; sin 'implicit' ni 'password'.	*N.A.*	Idem.
v5.0.0–10.4.5	Mitigar la repeticion del refresh token en clientes publicos.	*N.A.*	Idem.
V11 · Cryptography			
v5.0.0–11.3.1	Sin modos de cifrado inseguros (ECB) ni relleno PKCS#1 v1.5.	**Cumple**	Decision de diseño: se prohiben modos inseguros (ECB) y relleno PKCS#1 v1.5.
v5.0.0–11.3.2	Solo cifradores y modos aprobados (p. ej. AES-GCM).	**Cumple**	Decision de diseño: cifrado solo con AES-GCM.
v5.0.0–11.4.1	Solo funciones de hash aprobadas; MD5 prohibido para uso criptografico.	**Cumple**	Decision de diseño: solo funciones de hash aprobadas (p. ej. bcrypt/Argon2 para contraseñas); MD5 prohibido.
V12 · Secure Communication			
v5.0.0–12.1.1	Solo versiones recientes de TLS habilitadas (1.2/1.3).	**Cumple**	Decision de diseño: solo TLS 1.2/1.3 habilitados en todo el borde.
v5.0.0–12.2.1	TLS en toda conexion externa, sin caer a texto plano.	**Cumple**	Decision de diseño: toda conexion externa usa TLS, sin caida a texto plano.
v5.0.0–12.2.2	Certificados TLS de una autoridad publicamente confiable.	**Cumple**	Decision de diseño: certificados TLS de una autoridad publicamente confiable.
V13 · Configuration			
v5.0.0–13.4.1	Sin metadatos de control de versiones (.git/.svn) accesibles en produccion.	**Cumple**	Decision de despliegue: sin carpetas .git/.svn accesibles en produccion.
V14 · Data Protection			
v5.0.0–14.2.1	Datos sensibles en cuerpo/cabeceras, nunca en la URL o query string.	**Cumple**	Decision de arquitectura: tokens y datos sensibles viajan en cuerpo/cabeceras, nunca en la URL.
v5.0.0–14.3.1	Limpiar el almacenamiento del cliente al terminar la sesion.	*Pendiente*	Limpieza de almacenamiento del cliente al cerrar sesion: comportamiento de frontend a verificar en codigo.
V15 · Secure Coding and Architecture			
v5.0.0–15.1.1	Documentar plazos de remediacion por riesgo para componentes vulnerables.	**Cumple**	Decision de politica: plazos de remediacion por severidad (criticas 7 dias, altas 30 dias), documentados para este ejercicio.
v5.0.0–15.2.1	Que los componentes reales no incumplan esos plazos de remediacion.	*Pendiente*	Que los componentes reales no incumplan esos plazos: requiere un inventario/SCA del sistema desplegado.
v5.0.0–15.3.1	Las respuestas de la API devuelven solo el subconjunto de campos necesario.	**Cumple**	Decision de arquitectura: los endpoints devuelven proyecciones/DTOs explicitos, no la entidad completa.